

ShieldAI

The Virtual CISO Platform

Affordable today. A managed-security platform at scale.

BUSINESS PLAN

Confidential · 2026

Prepared by Xandu Limited, LLC

Live in production · [shieldai-production-627e.up.railway.app](#)

Contents

1. Executive Summary

“A full-time CISO costs \$200,000–\$400,000 a year. Nearly half of small businesses have no security budget at all — yet their insurers, customers, and regulators now require a real security program. ShieldAI closes that gap, and it is live in production today.”

ShieldAI is a virtual Chief Information Security Officer (vCISO) platform for small and mid-sized businesses (SMBs). It delivers a complete, continuously-managed security program — deterministic risk scoring, written policies, a prioritized roadmap, multi-framework compliance mapping, real threat intelligence, security-awareness training, and executive reporting — at a price a small business can actually afford. The platform is deployed and operational, not a concept.

Our strategy is a deliberate wedge-to-platform progression. We begin with an affordable, largely self-serve product that delivers immediate value and proves the model. As we grow, we layer human expertise on top: cybersecurity engineers who use ShieldAI to run full, managed CISO programs for a portfolio of clients — with the software and an AI co-pilot doing the heavy lifting so a small team can protect a large book of businesses. This is how we move from a low-cost tool to a high-value managed-security platform without a linear increase in headcount.

ShieldAI is powered by frontier AI for analysis and content generation, but our defensibility does not rest on the AI itself. It rests on three things: a proprietary, deterministic security-scoring engine built on the NIST Cybersecurity Framework (with a control-mapped CIS v8.1 alternate) that produces explainable, auditor- and insurer-trustworthy results; a human-in-the-loop model in which qualified engineers review and approve work before it reaches the client; and the proprietary assessment data and client relationships that compound over time.

Key Highlights

Metric	Detail
Target market	U.S. SMBs with employees, prioritizing regulated and insured segments
Core category	Virtual CISO (vCISO) — ~\$2B+ today, growing 12–15%+ annually
Demand driver	Cyber-insurance, customer security requirements, and regulation forcing SMBs to act
Model	Wedge: low-cost self-serve → Expand: engineer-run managed vCISO programs
Differentiation	Deterministic NIST + CIS scoring engine, human-in-the-loop, live analyst platform
Stage	Live in production: assessment, scoring, program & policy generation, real CVE/breach intel, compliance frameworks, training product, monitoring agents, analyst console, admin
Next milestone	Scale the managed book; hire first security engineers; Stripe billing to GA

This plan reflects ShieldAI’s current state: the self-serve product and the analyst platform are built and running in production. This raise funds go-to-market, the first security-engineer hires, and the automation that scales the managed book.

2. The Problem & Market Opportunity

2.1 The SMB Security Gap

Small businesses face the same threat landscape as enterprises — ransomware, phishing, business email compromise, supply-chain attacks — but lack the budget, expertise, or time to respond. They are caught in a structural bind: too big to ignore security, too small to afford a dedicated leader. A full-time CISO costs \$200,000–\$400,000 or more per year, while the foundational tools and expertise cost roughly the same whether a business has 10 employees or 100 — so the per-employee burden falls hardest on the smallest firms.

The data shows how exposed this segment is:

- 47% of businesses with fewer than 50 employees have no cybersecurity budget at all (StrongDM / CrowdStrike, 2025).
- 51% have no security measures in place; one-third rely on free, consumer-grade tools.
- Only 34% have a formal incident response plan (Guardz, 2025).
- Only ~13% conduct proactive security audits, and only ~1 in 5 performs annual penetration testing.
- Small businesses represent roughly 43% of all cyberattacks, and SMB incident rates rose ~47% year over year.

The cost of inaction is severe and quantifiable: IBM data shows a tested incident-response plan reduces breach cost by approximately \$232,000, and prevention investment returns consistently exceed 7x. A foundational program costing a few thousand dollars a year would save hundreds of thousands in the event of a breach — yet the businesses that spend nothing are the ones that pay the most.

2.2 Market Size

ShieldAI sits in the virtual CISO category, inside the broader SMB cybersecurity market.

Market	Size / Estimate	Source
U.S. small businesses	36.2M total; ~5.8M with employees	SBA Office of Advocacy, 2025
Global SMB cybersecurity spend	~\$109B by 2026, ~10% CAGR	Analysys Mason
Virtual CISO market (global)	~\$2B+ in 2025, 12–15%+ CAGR	Composite (multiple firms)
U.S. cyber-insurance market	~\$3.9B (2025), ~22% CAGR	Market Research Future

vCISO market estimates vary by research firm — from roughly \$1.06B to \$2.89B for 2024–25, with forecasts ranging from \$1.5B to \$12B by the early 2030s — because firms scope the category differently. Every credible source agrees on the direction: double-digit annual growth driven by escalating threats, a 3.4-million-person global cybersecurity talent shortage, and tightening compliance.

2.3 Market Sizing (Bottom-Up)

- TAM: The global vCISO category, ~\$2B+ and growing 12–15%+ per year — the market we directly serve.
- SAM: ~5.8M U.S. employer businesses, narrowed to regulated/insured/supply-chain segments (a conservative 10–20% → roughly 600K–1.2M businesses). At a blended program value in the low thousands per year, this is a multi-billion-dollar serviceable market.
- SOM: A modest, credible early capture — e.g., 1% of a 600K-business SAM — represents a business on the order of \$20M+ in annual recurring revenue, reached over a 3–5 year horizon via the self-serve-to-managed motion.

2.4 Why Now

The decisive shift is that demand is no longer driven by whether small businesses care about security — it is being forced on them by three external pressures converging at once:

- Cyber-insurance as gatekeeper: Insurers now require proof of specific controls (MFA, incident response, etc.) before issuing or renewing policies. 63% of SMBs saw premiums rise 200%+ in 2025, and businesses under \$25M in revenue filed 64% of all cyber-insurance claims — so insurers are tightening precisely on our target segment.
- Customer-driven requirements: Larger customers increasingly push security questionnaires and insurance requirements down to their small vendors. Without a demonstrable program, small businesses lose contracts.
- Expanding regulation: HIPAA, CMMC (defense supply chain), the FTC Safeguards Rule, and state privacy laws now carry real penalties — reaching deep into the small-business tier.

On the supply side, AI has only recently become capable enough to deliver expert-level security analysis and documentation at a cost that makes serving the small-business segment economically viable. The need and the means have arrived at the same moment.

3. Product & Platform

3.1 What the Customer Gets — Live Today

From a short, structured assessment, ShieldAI produces a complete security program through a unified dashboard. Every capability below is built and operating in production:

- Security assessment: a conversational intake plus a structured, framework-mapped checklist that captures the business's context and current posture; the client chooses a NIST, CIS, or blended scoring foundation at the start.
- Deterministic risk score: an explainable posture score with a per-function breakdown, computed by a deterministic engine — not an AI guess — with an alternate-framework view for clients who need it.
- Prioritized roadmap and task workspace: ranked actions with effort, impact, and ownership, wired to live remediation-task tracking rather than static AI text.
- Professional policy library: complete, formatted, ready-to-use policy documents, downloadable as Word files and tailored to the business.
- Multi-framework compliance mapping: control-mapped gap analysis across real frameworks (NIST CSF, CIS v8.1, HIPAA Security Rule, PCI-DSS, SOC 2, CMMC, and more) with remediation guidance.
- Real threat intelligence: live CVE exposure via the NVD/CVE database matched against each client's reported software, plus dark-web breach exposure via Have I Been Pwned — no fabricated security data.
- Security-awareness training: a standalone training product with tokenized learner links, quarterly scheduling, per-client and fleet reporting, and CSV export.
- Cross-platform monitoring agents (Windows, Linux, macOS): permanently read-only collectors that report installed software and versions for CVE matching, with no inbound command channel.
- Board-ready executive reporting, evidence/audit-readiness views, and notifications.

3.2 The Scoring Engine — Our Core IP

ShieldAI's differentiator is a deterministic risk-scoring engine built on the NIST Cybersecurity Framework, with a control-mapped CIS v8.1 alternate. Unlike an AI that "guesses" a number, the engine computes a posture score across the five NIST functions — Identify, Protect, Detect, Respond, and Recover — each weighted and scored from the structured assessment. The same inputs always produce the same score, and every point traces to a specific control. When a client selects a blended foundation, NIST remains the authoritative headline number for insurer and auditor compatibility while the CIS view is attached as an alternate, and the two are constrained to agree within a tight band so a business can never produce two contradictory verdicts.

This matters commercially: an insurer, auditor, or enterprise customer can trust an explainable, repeatable score in a way they would never trust an opaque AI output. The scoring methodology is proprietary and improves as our assessment dataset grows.

3.3 The Role of AI

Frontier AI powers the analytical and generative work — interpreting the assessment, drafting tailored policies, generating training and reporting, and (in the platform layer) assisting our engineers through the "Mastermind" co-pilot. The architecture is model-flexible through a unified provider layer that runs on Anthropic's Claude as primary, with Google Gemini and OpenAI GPT available and additional models incorporable where they add value. Two boundaries are deliberate and are a selling point: the Mastermind co-pilot is read-only and advisory — it never acts autonomously — and analysts are strictly isolated to their assigned clients. The AI accelerates expert work rather than replacing expert judgment, which is central to both our quality bar and our liability posture.

4. Strategy: Wedge to Platform

4.1 The Wedge — Self-Serve Product

The entry product is affordable and largely self-serve. A business completes an assessment, receives a real posture score and a complete program, and can generate and download professional policies — immediate, tangible value at a fraction of the cost of a consultant. A free tier lets a business run an assessment and see its score at no cost, converting curiosity into a qualified lead. This wedge gets businesses in the door cheaply, proves the model, and builds the assessment dataset that strengthens our scoring engine.

4.2 The Expansion — Managed vCISO Programs

As clients grow or face greater compliance demands, they graduate to managed plans in which a ShieldAI cybersecurity engineer runs their security program on an ongoing basis. This is higher-value, higher-retention recurring revenue, and it is where the human-in-the-loop model delivers both quality and trust.

4.3 The Platform — The Analyst Console (Live)

The engine of scale is the analyst console: a command center where each engineer manages a portfolio of client businesses. From a single interface an engineer monitors every client's posture and trend over time, reviews CVE and breach exposure, tracks compliance and training, and reviews and approves the AI's work before it ships. Analysts are strictly scoped to their assigned clients. The integrated "ShieldAI Mastermind" co-pilot triages threats, diagnoses issues, and surfaces compliance gaps in a read-only, advisory capacity, so one engineer can do what previously required a whole team.

This console is live in production today, not a mockup. This raise funds the go-to-market motion and the first engineer hires that turn a working platform into a scaled managed book. This is the layer that transforms cybersecurity consulting from a headcount-bound business into a scalable platform.

The AI does the first 80%. The engineer adds the high-value 20% — judgment, accountability, and the client relationship. That blend is our margin and our quality bar.

5. Business Model

5.1 Revenue Streams

- Self-serve subscriptions — low-cost, high-volume entry tiers; the wedge.
- Managed vCISO plans — engineer-run programs; the primary recurring-revenue engine.
- Add-ons — security-awareness training delivery (\$40/month at Starter, bundled at Growth and above), compliance-readiness packages, cyber-insurance documentation, and specialized policy work.
- Channel / partnerships — referrals from cyber-insurers, MSPs, and professional-services firms whose clients must demonstrate controls (a natural low-CAC path).

5.2 Pricing Tiers

Pricing is set to undercut traditional human-only vCISO retainers — which typically run \$2,500–\$11,600/month for SMB clients — while remaining more complete than automated-only tools. Because AI performs the heavy lifting, ShieldAI can price for real SMB budgets and still hold healthy margins. The five-tier ladder is designed for land-and-expand:

Tier	Price / mo	What it includes	Target customer
Free	\$0	Assessment + NIST/CIS posture score; a taste of the program	Lead generation; micro-businesses evaluating
Starter	\$159	Full self-serve program, policy generation, compliance mapping, and the AI-recommended training plan — no human time	Micro-businesses; the paid wedge
Growth	\$349	Starter plus threat intel, the full employee training delivery product, and expanded framework tracking	Growing SMBs formalizing a program
Guided	\$699	Growth plus periodic engineer review, compliance tracking, and check-ins	SMBs with light compliance needs
Managed vCISO	\$1,950	A ShieldAI engineer runs the program end-to-end — still below human-only competitors	Regulated / insured / supply-chain SMBs

The ladder is designed for land-and-expand: a business can enter free, convert to Starter at \$159/month, and grow into managed plans as trust builds and compliance demands increase. Training is packaged to reinforce that motion: Starter includes the AI-recommended training plan, and the full employee training delivery product (tokenized learner links, assignments, quarterly scheduling, and completion reporting) is a \$40/month add-on at Starter and bundled free at Growth and above. The managed tier deliberately sits at or below the bottom of the traditional retainer range — “a fractional CISO at a fraction of the cost.” Tier enforcement is implemented backend-first (structured HTTP 402 responses); UI gating is UX only. Stripe billing is integrated and staged for general availability.

5.3 Unit Economics — The Scalability Engine

The defining economics are at the managed tier, where the analyst console and AI co-pilot let a single cybersecurity engineer manage roughly 25 clients at a high-touch service level. The figures below reflect a hand-verified unit-economics model, not planning shorthand.

Metric	Value
Managed price	\$1,950 / month
Clients per engineer	~25 (enabled by the AI-amplified console)
Revenue per engineer (managed)	~\$585,000 / year

Metric	Value
Fully loaded engineer cost	~\$140,000 / year
AI cost per client	~\$0.28 / client / month (measured, not estimated)
Managed-tier gross margin	~75%
Blended gross margin (all tiers)	~60%

A correction from earlier drafts: measured AI cost is ~\$0.28 per client per month — far below the ~\$15 previously assumed — so AI cost is not a meaningful constraint. The ~75% margin applies to the managed tier; blended across the self-serve tiers the gross margin is ~60%. The binding constraint on the model is churn, not price or AI cost. Self-serve and Growth tiers add high-margin, low-touch revenue on top of the managed engine.

This is the crux of the investment thesis: revenue scales with the client book while engineer headcount grows far more slowly, because the software does the heavy lifting. Margins improve further as the assessment dataset and automation mature.

6. Financial Projections

The following is an illustrative three-year ramp based on the pricing and unit economics above. It assumes a deliberate mix shift toward managed clients as the platform matures, with engineer headcount scaling to support the managed book at ~25 clients each. Headcount reflects the corrected model: managed clients — not total clients — drive engineer hiring, so Year-3 security engineering scales to roughly two dozen as the managed book grows.

	Year 1	Year 2	Year 3
Free / Starter clients	180	550	1,300
Growth clients	40	150	420
Guided clients	30	120	350
Managed clients	20	95	300
Total paying clients	270	915	2,370
Security engineers	1	5	23
Annual Recurring Revenue	~\$1.0M	~\$4.0M	~\$11M
Blended gross margin	~55%	~58%	~60%

These figures illustrate the model's shape and the operating leverage of the engineer-plus-AI structure; they are planning estimates, not commitments, and will be refined with real acquisition and retention data. Engineer headcount is driven by the managed book (~25 managed clients per engineer), which is why it scales faster in later years as managed mix grows. The key dynamic remains: ARR grows faster than the cost base, and the binding constraint is retention, which the managed tier and continuous monitoring are designed to defend.

7. Competitive Landscape & Defensibility

7.1 The Landscape

Category	Examples	Limitation	ShieldAI Edge
Traditional vCISO / consultancies	Fractional CISO, FRSecure, Kroll	Human-only; expensive; priced for mid-market+	AI does the heavy lifting — we serve the small end profitably
AI-native vCISO platforms	Cynomi, RealCISO, Trava	Cynomi is MSP-facing and advises against pricing under \$1,500/mo	Direct-to-SMB below \$1,500 is structurally uncontested; deterministic scoring IP + managed hybrid
GRC / scoring tools	SecurityScorecard, CyberSaint	Scoring or compliance only; not a full program	Complete program + human-managed delivery
MSPs / DIY tools	Managed IT add-ons, templates	Tools without strategy or CISO-level judgment	We deliver the CISO function, not just tooling

Cynomi, the most-cited AI-native competitor, sells to MSPs rather than directly to SMBs and advises its MSP partners not to price under \$1,500/month — leaving the sub-\$1,500 direct-to-SMB segment we target structurally uncontested.

7.2 Why We Win

- Proprietary scoring methodology: explainable, repeatable, and trusted by insurers and auditors — not an opaque AI guess.
- Human-in-the-loop: expert review makes output trustworthy enough to sell and materially limits liability.
- Real data, not fabrication: live CVE and breach intelligence and control-mapped frameworks — verifiable under diligence, unlike invented security data.
- Compounding data and relationships: every assessment and managed client makes the system smarter and stickier.
- The AI is the commodity; the system around it — methodology, workflow, engineers, data — is the moat. A well-funded competitor cannot trivially replicate the whole system.

8. Product Roadmap

Phase 1 — Live Today: The Full Platform

- Conversational intake + structured checklist; deterministic NIST/CIS posture scoring with framework choice.
- AI-generated security program: roadmap, policies, compliance mapping across real frameworks, workflows, training, executive report.
- Real threat intelligence (NVD/CVE + HIBP), cross-platform read-only monitoring agents, standalone training product.
- Live analyst console with client isolation and read-only Mastermind co-pilot; tiered subscriptions with backend enforcement; admin tooling.

Phase 2 — This Raise: Scale the Managed Book

- Go-to-market: channel partnerships (insurers, MSPs) and demand generation to fill the funnel.
- Hire and onboard the first cybersecurity engineers to run managed programs.
- Stripe billing to general availability; automated program reporting and compliance progress cadence.
- Deepen the review-and-approval workflow and per-client SLAs at scale.

Phase 3 — Scale: Telemetry & Automation

- Expand agent telemetry into continuous posture and threat monitoring with automated alerting.
- Agent-fed recommendations and broader automation of low-judgment work.
- Vertical expansion and additional compliance frameworks; SOC 2 for ShieldAI itself.

9. Team & Execution

ShieldAI is being built by Xandu Limited, LLC. The product is already developed, deployed, and functioning in production — demonstrating execution capability and meaningfully de-risking the technical plan. The immediate organizational priority funded by this raise is hiring the first cybersecurity engineers — the people who run managed client programs through the analyst console — alongside continued product engineering and go-to-market.

The founder brings approximately 20 years of cybersecurity experience spanning national-security roles, enterprise CISO work, and hands-on SMB security-program delivery, with credentials including CISSP, CISM, and CompTIA Security+, a double M.S. in Cybersecurity, an MBA in IT Management, and a doctorate in Cybersecurity in progress. Because the platform model amplifies each engineer with AI, the team can stay lean relative to the size of the client book it supports. Security leadership and qualified engineering talent are the key early hires, given that the managed offering depends on credible, accountable human expertise.

10. The Ask & Use of Funds

ShieldAI is raising \$900,000 in seed funding to scale a working, in-production platform into a growing managed-security business over the next 18 months. Because the product is already built, this capital goes primarily to demand and delivery — not to proving the technology.

Use of Funds	Amount	%
Go-to-market & channel partnerships	\$300,000	33%
First security engineers (2–3 hires)	\$280,000	31%
Engineering (automation, telemetry, billing GA)	\$210,000	24%
Operations, SOC 2, legal & compliance	\$80,000	9%
Working capital reserve	\$30,000	3%

This capital takes ShieldAI to Series A readiness by approximately Month 18: a managed-services platform scaling in production, the first cohort of engineers running client programs, an ARR run-rate on the order of \$3M, and proven managed-tier retention and unit economics.

A full-time CISO costs a quarter-million dollars a year. ShieldAI delivers that protection for the price of a subscription — and the platform lets a handful of our engineers protect thousands of businesses. The technology is done; this raise scales the business.

11. Risk Analysis & Mitigation

Risk	Mitigation
AI output accuracy / hallucination	Deterministic scoring engine for the trust-critical number; human engineer reviews and approves all client-facing deliverables before release; Mastermind co-pilot is read-only and advisory.
Liability if a managed client is breached	Human-in-the-loop accountability; clear scope and terms on the self-serve tiers; appropriate professional and cyber insurance; SOC 2 posture on the roadmap.
Well-funded competitor (AI-native vCISO)	Differentiate on proprietary scoring methodology, the managed-services + platform model, real verifiable data, and accumulated relationships rather than the AI alone.
AI API cost or terms change	Model-flexible provider layer; measured AI cost is ~\$0.28/client/mo, so exposure is small; proprietary logic and scoring sit above any single provider.
Customer churn (“security feels done”)	Managed plans, continuous monitoring, training cadence, and compliance cycles anchor retention — the model’s binding constraint, addressed by design.
Scaling human expertise	The analyst console + read-only AI co-pilot let each engineer manage ~25 clients without linear headcount growth.

12. Summary

ShieldAI addresses a large, underserved, and — critically — a forced-demand market: tens of millions of small businesses that now must demonstrate a real security program but cannot afford to staff one. We enter with an affordable, working, in-production self-serve product and expand into high-value managed programs delivered by cybersecurity engineers who are amplified by our software and AI co-pilot.

Our defensibility is a system, not a feature: a proprietary, explainable NIST/CIS scoring engine; a human-in-the-loop model that makes our output trustworthy enough to sell; real, verifiable threat and compliance data; and the relationships that compound with every client. The product is already built and live. This fundraise funds the go-to-market and delivery that turn it into a scalable business.

ShieldAI · Confidential · 2026